

Infraestructura y seguridad

1. Introducción y Metodología

Este documento actúa como anexo y actualización directa a la Memoria Técnica de Infraestructura Core y al Informe Técnico de Red del proyecto "Daily Dose". Detalla la resolución de problemas de conectividad en la DMZ, la implementación de la sonda de seguridad, la configuración final del Centro de Operaciones de Seguridad (SOC) visualizado en Grafana, y la arquitectura de despliegue en la nube. La metodología empleada ha sido de gestión In-Band mediante SSH para asegurar la trazabilidad y facilitar el volcado de configuraciones complejas en el enrutador.

2. Memoria Descriptiva de la Topología y Segmentación

El núcleo del sistema perimetral está gestionado por el sistema operativo VyOS, el cual centraliza el enrutamiento inter-VLAN, la traducción de direcciones (NAT), el servidor Kea DHCP y el firewall con estado de inspección. Para mitigar vectores de ataque y optimizar los dominios de difusión, la infraestructura se ha segmentado estratégicamente en cinco zonas lógicas e independientes:

- **Zona WAN (Internet):** Interfaz física eth0 (192.168.1.165/24). Provee conectividad global como punto de salida hacia el ISP y servicios Cloud (AWS).
- **Red Interna Daily-Dose (LAN):** Interfaz física eth1 (192.168.10.1/24). Segmento restringido para estaciones de trabajo internas, TPVs y administración.
- **VLAN Invitados (VLAN 20):** Subinterfaz eth2.20 (172.16.0.1/24). Red wifi pública dedicada al aislamiento de usuarios ajenos con aislamiento de Capa 3.
- **VLAN Reuniones (VLAN 40):** Subinterfaz eth2.40 (192.168.40.1/24). Segmento optimizado de alta disponibilidad para salas de videoconferencias.
- **Zona DMZ Servidores:** Interfaz física eth3 (10.0.0.1/24). Dedicada en exclusiva al aislamiento de sistemas expuestos y herramientas críticas como Nagios Core.

3. Matriz de Direccionamiento e Interfaces

Una vez definida la política general de tránsito (Zero Trust), se procedió a la implementación detallada del juego de reglas en la cadena *forward filter* de VyOS 1.4. Para garantizar un filtrado determinista y evitar colisiones de tráfico o movimientos laterales no autorizados, todas las directivas de bloqueo y permisión se han vinculado explícitamente a sus correspondientes interfaces lógicas y virtuales (*inbound-interface* y *outbound-interface*).

A continuación, se detalla el volcado completo de comandos estructurados que dan soporte a la lógica perimetral de la plataforma, incluyendo el aislamiento estricto de las zonas de acceso público (Invitados y Reuniones) y la apertura controlada de flujos para la monitorización centralizada (Nagios/Loki) entre la LAN interna y la DMZ:

Origen	Destino	Servicio/Descripción	Acción	Regla
WAN (eth0)	DMZ (eth3)	Tráfico HTTP (80) y Grafana (3000)	Permitir	50, 60
Invitados (eth2.20)	WAN (eth0)	Salida general a Internet	Permitir	100
Invitados (eth2.20)	LAN, Reuniones, DMZ	Aislamiento estricto de la subred	Bloquear	110, 120, 130
Reuniones (eth2.40)	WAN (eth0)	Salida general a Internet	Permitir	200
Reuniones (eth2.40)	LAN, Invitados, DMZ	Aislamiento estricto de la subred	Bloquear	210, 220, 230
DMZ (eth3)	WAN (eth0)	Salida general a Internet	Permitir	300
DMZ (eth3)	LAN (eth1)	Sondas de Nagios hacia la red interna	Permitir	310
LAN (eth1)	DMZ (eth3)	Envío de logs y métricas pasivas	Permitir	400

4. Configuración de Conmutación y Automatización DHCP

Para transportar los flujos aislados sobre el mismo medio físico de la interfaz eth2, se desplegó el estándar IEEE 802.1Q (VLAN Tagging) mediante switches en cascada dentro de GNS3.

El router VyOS actúa como autoridad única de direccionamiento mediante Kea DHCPv4. Durante el despliegue de este servicio se solventaron las siguientes incidencias:

- **Validación "Subnet-ID":** El motor Kea en VyOS 1.4 requiere un identificador único para mapear las concesiones; esto se resolvió incluyendo los parámetros subnet-id 10 y 20 en las definiciones.
- **Validación de Gateway:** El sistema fallaba al validar el default-router antes de persistir la subred. Se solucionó aplicando una configuración atómica: declaración de red/rango, ejecución de commit y posterior declaración de opciones.

5. Arquitectura del Firewall Perimetral y Reglas de Aislamiento

La seguridad se rige bajo la premisa de Mínimo Privilegio (Zero Trust) utilizando el motor nftables. Se implementaron las siguientes políticas:

- **Política de Tránsito Global:** Se configuró la cadena forward filter con una acción por defecto de drop. Al no existir directivas explícitas de aceptación entre las redes, el sistema destruye nativamente cualquier tráfico no autorizado inter-VLAN.
- **Stateful Inspection:** Se insertó una regla para permitir de forma inmediata las respuestas del tráfico saliente aprobado (estados established y related).
- **Troubleshooting Sintáctico:** Debido a que VyOS 1.4-rolling invalida la sintaxis clásica exigiendo especificar la familia, la política se reconstruyó bajo la jerarquía firewall ipv4 name.

6. Restauración de Conectividad en la DMZ

Durante las pruebas, se detectó que el servidor Nagios alojado en la DMZ (10.0.0.0/24) carecía de salida a Internet para descarga de paquetes y APIs. La auditoría en VyOS evidenció la ausencia de políticas de enmascaramiento y reenvío.

- **Resolución NAT:** Se configuró una regla de Source NAT (regla 120) para la subred 10.0.0.0/24 con traducción masquerade por la interfaz eth0.
- **Resolución Firewall:** Se añadió la regla 300 en el filtro forward para permitir explícitamente el tránsito de salida hacia Internet desde la DMZ.

7. Arquitectura de Monitorización Reactiva (SOC)

Una vez restaurada la conectividad, se implementó la cadena de monitorización del proyecto:

- **Detección (Nagios):** Aislado en la DMZ. Se configuró con una arquitectura Multihoming en Virtual-Box: una interfaz en Adaptador Puente para gestión SSH local (192.168.1.X) y otra en Red Interna estática (10.0.0.20) para integrarse con VyOS de forma segura.
- **Automatización (Python):** Se configuró el script sonda_loki.py como Event Handler para capturar los cambios de estado.
- **Ingesta (Loki):** Almacenamiento centralizado de logs etiquetados.
- **Visualización (Grafana):** Dashboard ejecutivo para auditoría en tiempo real.

8. Diario de Troubleshooting del SOC (Grafana & Loki)

Durante la integración visual, se superaron tres incidencias críticas:

- **Incidencia 01 (Error de DOM en React):** La interfaz colapsaba (NotFoundError) al intentar agrupar dataframes dispares en un panel Stat único. Se resolvió desagregando las consultas y estableciendo la propiedad Display Mode a "All values" con orientación horizontal, logrando un aspecto modular.
- **Incidencia 02 (Ilegibilidad por Metadatos):** Grafana pintaba por defecto todas las etiquetas técnicas de Loki, saturando el panel. Se aplicaron Field Overrides en la propiedad Display name para forzar la traducción a términos ejecutivos como "Tráfico" o "Alertas".
- **Incidencia 03 (Ausencia de Eventos de Alertas):** El panel mostraba que no había alertas porque el componente nativo de Grafana está diseñado para reglas internas, no para logs externos. Se sustituyó por una visualización tipo Logs consultando {job="alertas-seguridad"}.

9. Validación de Entorno y Auditoría Forense

- **Aislamiento y Servicios:** Las pruebas empíricas confirmaron la estanqueidad de la red; los pings entre la red de Clientes y Reuniones resultaron en denegación silenciosa (Time Out). Además, el ciclo DORA de DHCP en los terminales VPCS se completó en menos de un segundo.
- **Simulación SOC:** Para certificar el sistema forense, se lanzó una alerta manual desde consola (/usr/bin/python3 /usr/local/bin/sonda_loki.py CRITICAL). El evento fue capturado instantáneamente por Loki y expuesto en Grafana, validando el Bloque 2 del TFC.

10. Arquitectura Cloud: Despliegue en AWS y Protección Perimetral mediante Cloudflare

Para complementar la infraestructura de red corporativa simulada y proveer acceso externo robusto y de alta disponibilidad a la plataforma "Daily Dose", se ha implementado una arquitectura de nube híbrida. Esta integración desplaza los servicios públicos críticos hacia **Amazon Web Services (AWS)**, asegurados en el perímetro por **Cloudflare**.

10.1. Infraestructura de Alojamiento en AWS

El núcleo de la aplicación de cara al público se aloja en un entorno en la nube, garantizando escalabilidad, disponibilidad y aislamiento del tráfico interno corporativo. Los componentes desplegados son:

- **Instancia de Cómputo (Servidor Web):** Se ha aprovisionado una máquina virtual en AWS que actúa como servidor web principal, hosteando el código fuente y la interfaz de la plataforma web de Daily Dose. Esta instancia procesa las solicitudes web y mantiene la lógica de negocio alejada de la infraestructura física del centro de datos local.
- **Motor de Base de Datos:** El almacenamiento estructurado y la persistencia de los datos críticos de la aplicación se mantienen en un servicio de base de datos administrado dentro del ecosistema de AWS. Esta separación de capas (cómputo y almacenamiento) facilita la escalabilidad de la base de datos de manera independiente al frontend y asegura la persistencia segura de la información.

10.2. Integración del Proxy Inverso Cloudflare

Como medida de protección proactiva y optimización de rendimiento global, la infraestructura alojada en AWS se encuentra escudada tras un proxy inverso proporcionado por Cloudflare. Este actúa como el intermediario único y obligatorio entre el navegador web de los usuarios finales y los servidores de AWS.

Característica de Cloudflare	Impacto y Beneficios en la Arquitectura (Daily Dose)
Ocultación de IP (Reverse Proxy)	Al hacer de intermediario, enmascara la dirección IP real de la máquina virtual de AWS. Los usuarios y posibles atacantes solo interactúan con la red perimetral de Cloudflare.
Terminación SSL/TLS y Cifrado	Garantiza que todas las conexiones desde el navegador del cliente hasta la plataforma estén cifradas mediante certificados de seguridad robustos, evitando la interceptación de datos (Man-in-the-Middle).
Mitigación de Ataques DDoS	Filtra y absorbe picos de tráfico anómalo o malicioso antes de que puedan alcanzar e impactar la máquina virtual de AWS, protegiendo la disponibilidad de la web de Daily Dose.
Caché de Contenido Perimetral	Almacena en memoria caché los recursos estáticos en servidores cercanos al usuario, disminuyendo la latencia de carga en el navegador y reduciendo significativamente la carga de procesamiento del servidor AWS.

Mediante esta integración, el proyecto «Daily Dose» cuenta con un modelo de defensa en profundidad para su exposición pública: filtrado y aceleración global en la capa de borde (Cloudflare), y procesamiento y persistencia escalables en el núcleo de la nube (AWS EC2 y Base de Datos).